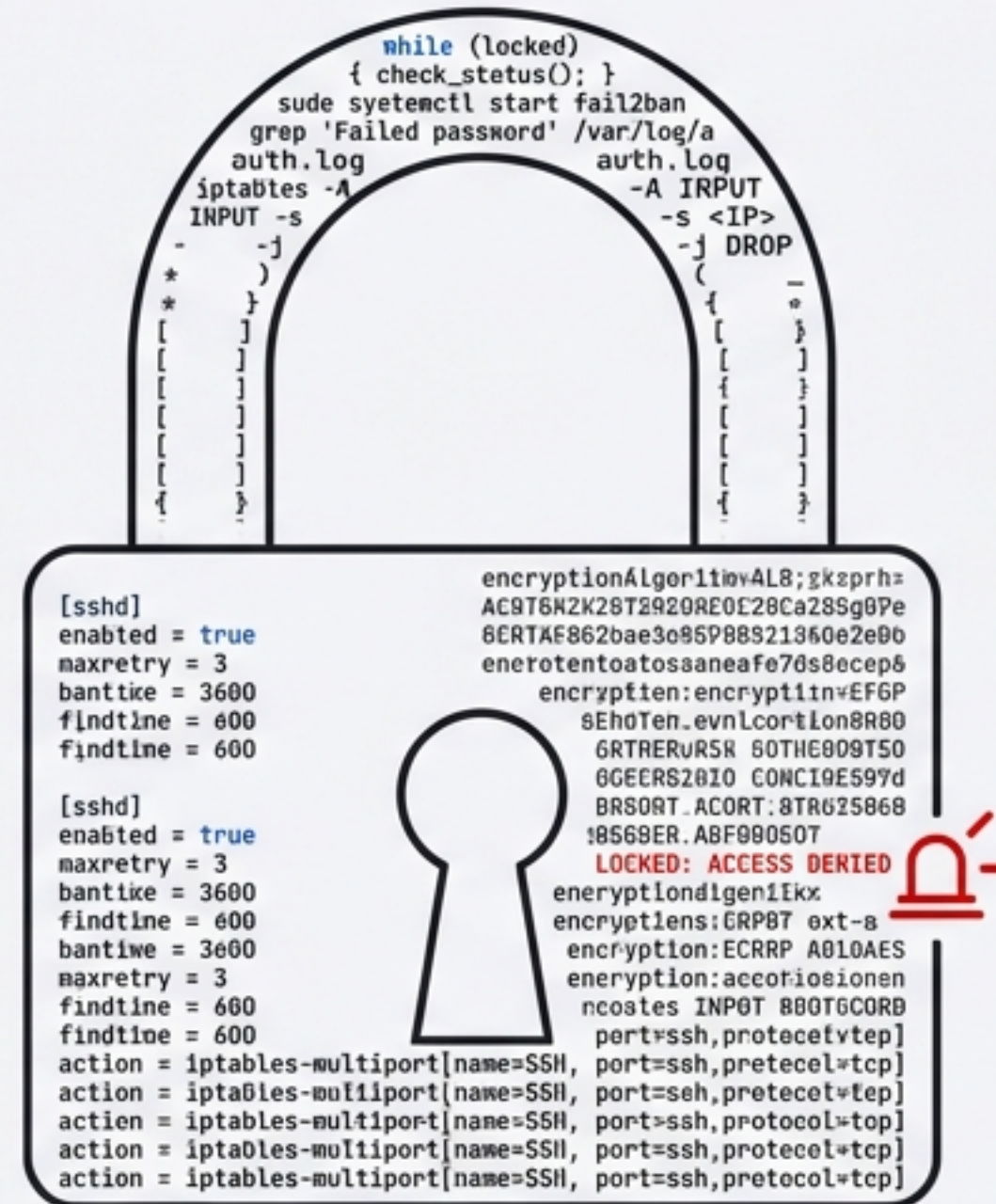


Defensa Automatizada contra Fuerza Bruta con Fail2Ban

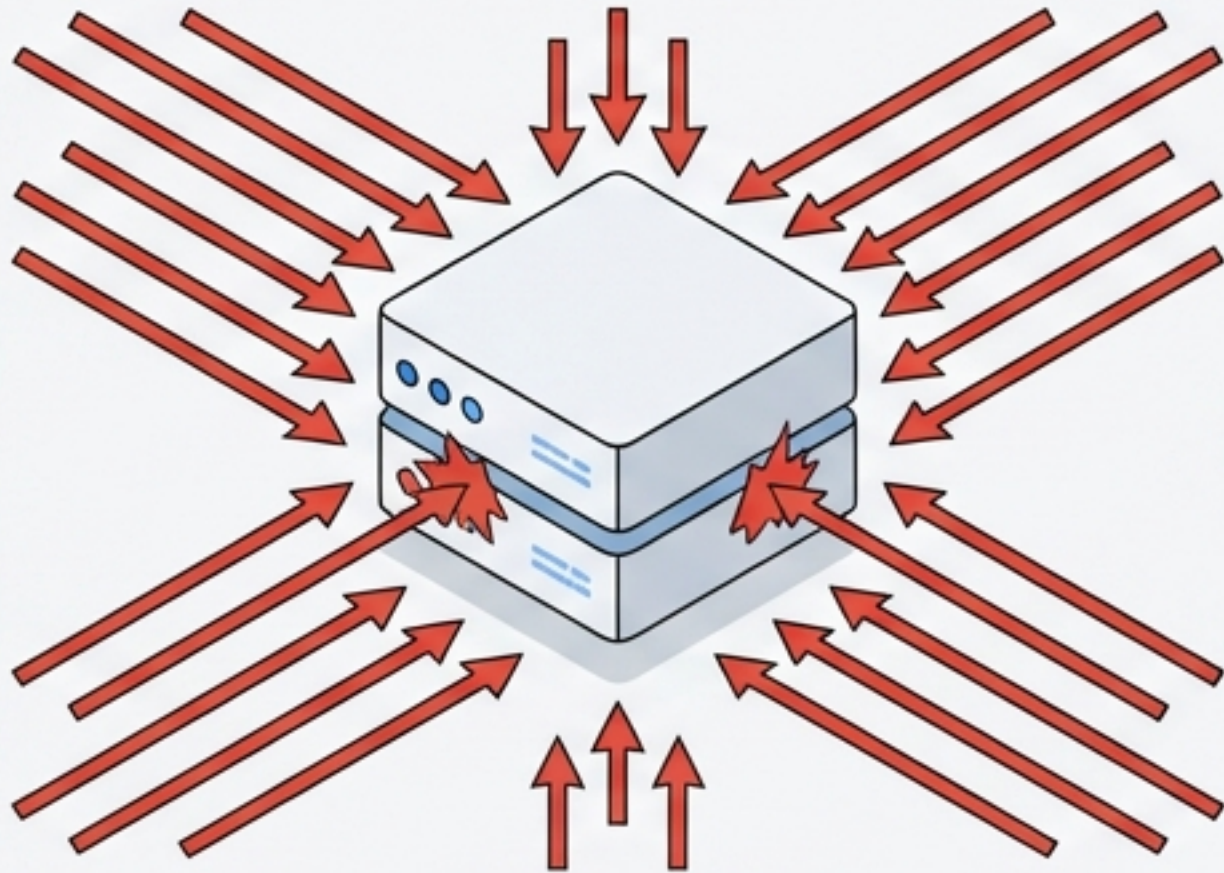
Guía de Hardening para Servidores Linux



El Objetivo y La Amenaza

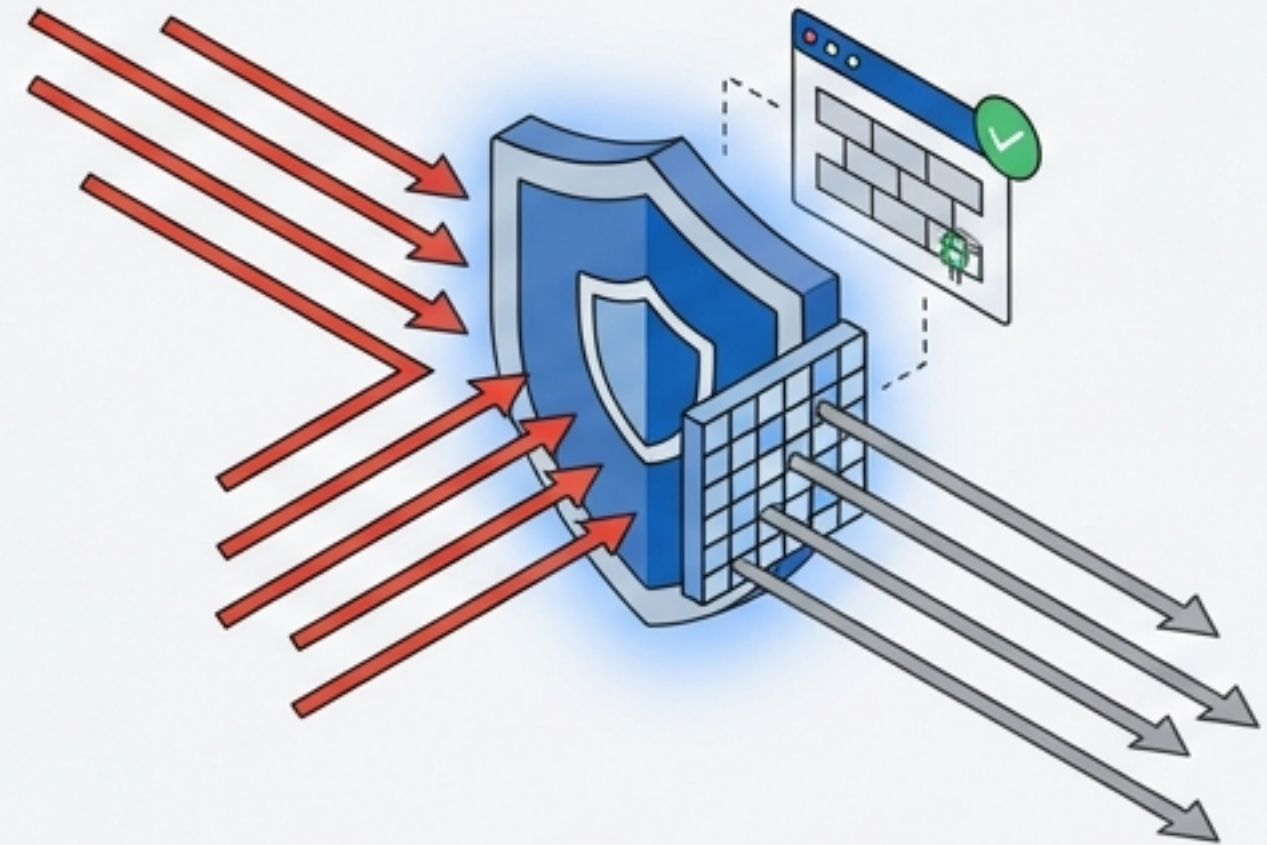
Ataque de Fuerza Bruta

Intentos masivos y automatizados de adivinar credenciales. El servicio SSH (puerto 22) es el vector de ataque más común en servidores expuestos.



Fail2Ban

Herramienta de prevención de intrusiones que escanea archivos de registro (logs) y bloquea direcciones IP maliciosas actualizando dinámicamente las reglas del firewall.



Objetivo: Bloquear automáticamente IPs maliciosas sin intervención humana.

Anatomía de la Defensa: Flujo de Trabajo



Prerrequisito: Estado del Servicio SSH

Antes de instalar la defensa, verificamos el terreno.

Sistema base: Ubuntu/Debian.

Verificación

```
sudo apt update && sudo apt
install openssh-server -y
systemctl status ssh
```

Debe indicar
"active
(running)"

Habilitación

```
sudo systemctl start ssh
sudo systemctl enable ssh
sudo ss -tulpn | grep ssh
```

Resultado
esperado:
0.0.0.0:22

Firewall Base

```
sudo ufw allow ssh
sudo ufw reload
```


Despliegue: Instalación de Fail2Ban

01

Instalación

```
sudo apt install fail2ban -y
```

Compatible con Ubuntu/Debian (y CentOS/RHEL con variaciones menores).

02

Comprobación Inicial

```
sudo systemctl status fail2ban
```

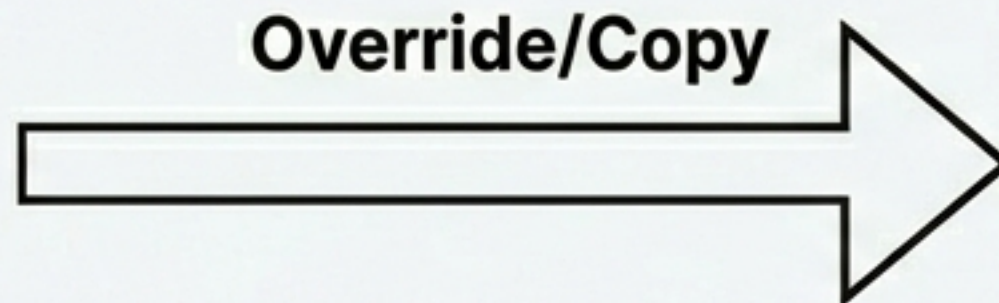
- fail2ban.service - Fail2Ban Service
Loaded: loaded (/lib/systemd/system/fail2ban.service; vendor preset: enabled)
Active: **active (running)**

La Regla de Oro de la Configuración



✗ /etc/fail2ban/jail.conf

Template del sistema. NO EDITAR.
Se sobrescribe con las actualizaciones.



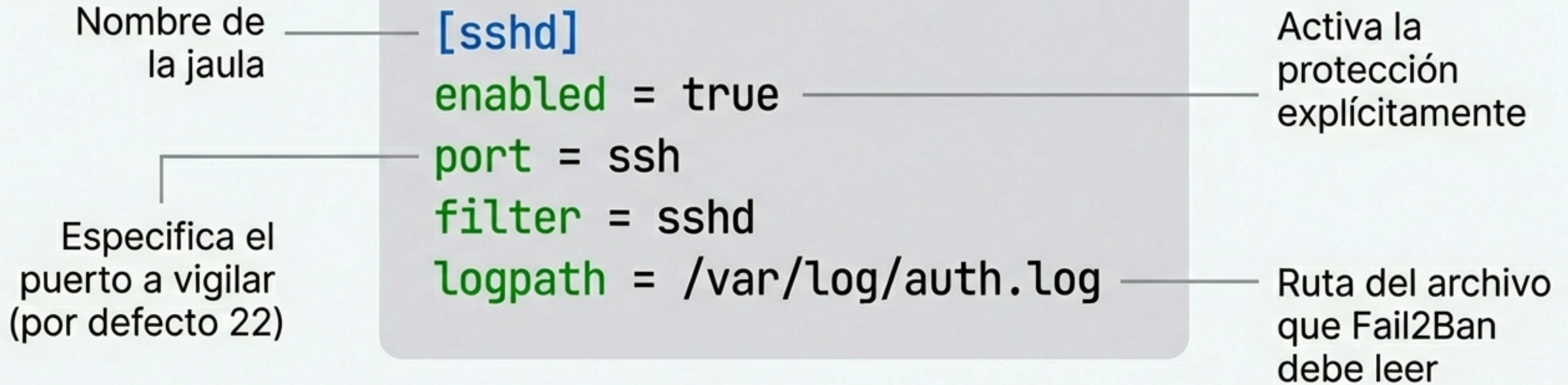
✓ /etc/fail2ban/jail.local

Archivo de usuario.
Prioridad sobre .conf.

Crear el archivo de configuración local:

```
sudo nano /etc/fail2ban/jail.local
```


Definiendo la 'Celda': Configuración SSH



Parámetros de Sensibilidad y Castigo

```
maxretry = 3  
findtime = 600  
bantime = 600
```

maxretry

Tolerancia



Número de intentos fallidos permitidos antes del bloqueo (Ej: 3).

findtime

Ventana de Memoria



Ventana de tiempo donde se cuentan los fallos (Ej: 600s).
Si fallas 3 veces en 10 minutos → Ban.

bantime

La Sentencia



Duración del bloqueo en segundos (Ej: 600s = 10 min).

Activación del Sistema

Reinicio y Persistencia

```
sudo systemctl restart fail2ban  
sudo systemctl enable fail2ban
```

Verificación de Celdas

Comprobar el estado del cliente:

```
sudo fail2ban-client status
```

```
Status  
|- Number of jail:    1  
`- Jail list:        ssshd
```

Indica que la protección SSH está activa.

Simulación de Ataque (Pentesting Controlado)

¡Cuidado! Realizar desde una IP externa (móvil/otra red). No bloquear la propia conexión de administración.

The Attack

Desde máquina atacante

```
ssh usuario@tu_ip -p 22
```

Introducir contraseñas incorrectas hasta superar maxretry.

The Result

En el servidor protegido

```
sudo fail2ban-client status sshd
```

Banned IP list

192.168.1.45

Gestión de Incidentes: Unban y Logs

Desbloqueo Manual

Falso positivo: Un usuario legítimo ha olvidado su contraseña.

```
sudo fail2ban-client set sshd unbanip 192.168.1.42
```

Auditoría Forense (Logs)

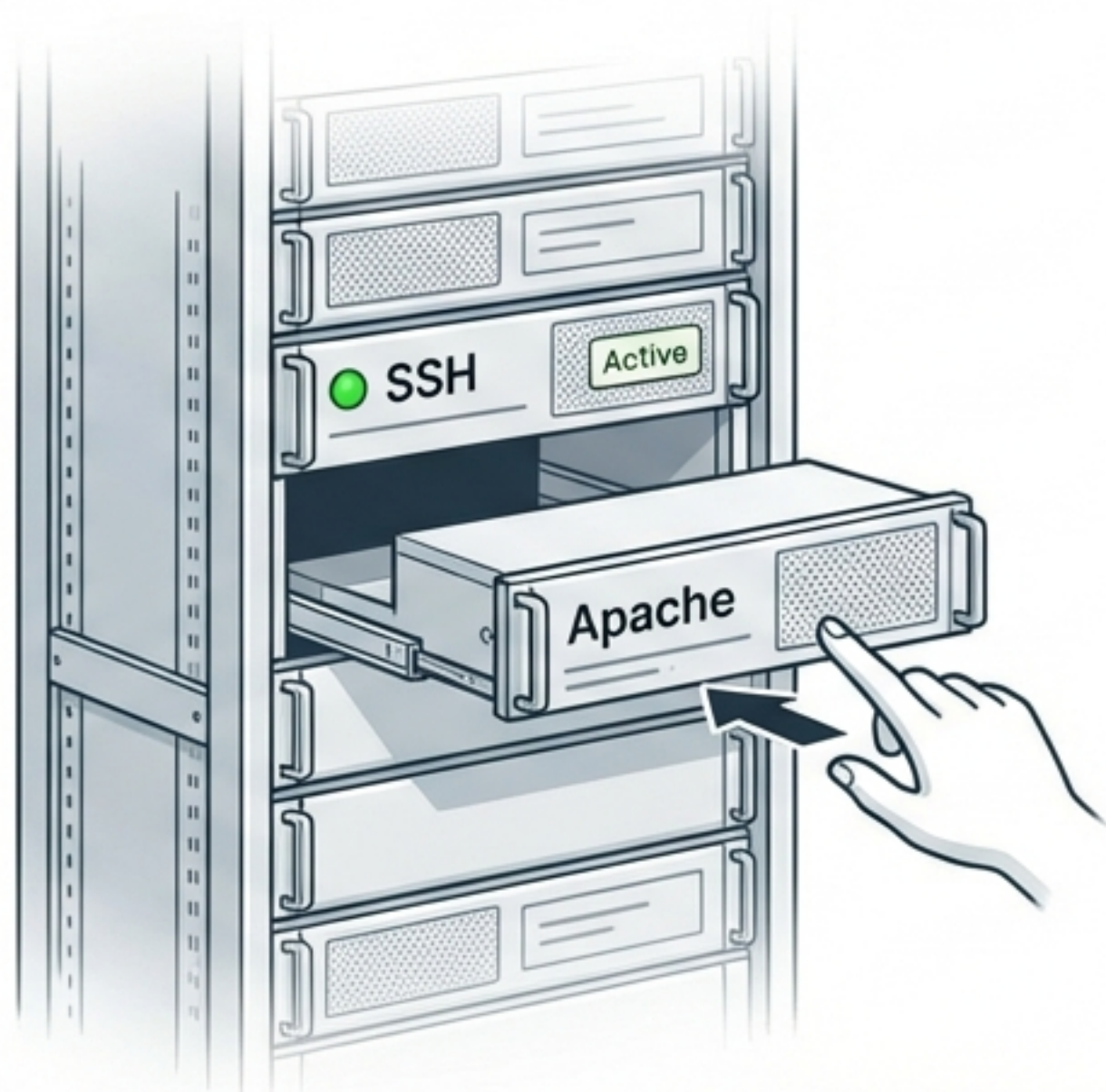
Revisar historial de bloqueos y actividad.

```
sudo tail -f /var/log/fail2ban.log
```

```
[2023-10-27 10:15:22] fail2ban.actions [1423]: NOTICE  
[sshd] Ban 192.168.1.42  
[2023-10-27 10:15:24] fail2ban.filter [1423]: INFO  
[sshd] Found 192.168.1.43 - 2023-10-27 10:15:24  
[2023-10-27 10:15:26] fail2ban.actions [1423]: NOTICE  
[sshd] Ban 192.168.1.43  
[2023-10-27 10:16:01] fail2ban.actions [1423]: NOTICE  
[sshd] Unban 192.168.1.42  
[2023-10-27 10:17:12] fail2ban.filter [1423]: INFO  
[sshd] Found 10.0.0.55 - 2023-10-27 10:17:12
```


Extensión del Perímetro (Más allá de SSH)

Fail2Ban es modular. Se pueden crear filtros para Apache, Nginx, Postfix, Dovecot, etc.



Ejemplo: Protección Apache (Auth)

```
[apache-auth]
enabled = true
port = http,https
logpath = /var/log/apache*/error.log
maxretry = 5
```


Estrategias Avanzadas: Sentencia y Alerta



Bloqueo Permanente

```
bantime = -1
```

La IP queda bloqueada indefinidamente. Útil para reincidentes persistentes.



Notificaciones

Configuración de envío de correos electrónicos automáticos tras cada bloqueo. Recomendado para servidores de producción crítica.

Resumen Ejecutivo y Mejores Prácticas



Monitoreo

Revisar regularmente
`/var/log/fail2ban.log`.



Firewall

Fail2Ban administra el firewall automáticamente; asegurar que UFW/iptables esté activo.



Regex

La eficacia depende de filtros bien definidos para detectar ataques.



Hardening

Fail2Ban es una capa extra, no sustituye contraseñas fuertes o llaves SSH.

Defensa activa implementada.